# Protocolo de seguridad, incidentes y solicitudes — borrador operativo

**Versión de trabajo:** 0.1, 16 de octubre de 2026 · **Estado:** por asignar responsables, infraestructura, plazos de conservación y revisión jurídica/técnica. No acredita que todos los controles estén implementados.

## 1. Responsables y activos

**Titular del proyecto/responsable del tratamiento:** [pendiente]. **Persona de privacidad y solicitudes:** [pendiente]. **Responsable técnico de incidentes:** [pendiente]. **Sustituto y contacto fuera de horario:** [pendiente]. **Abogada revisora:** [pendiente]. Mantener un registro restringido de decisiones, accesos y pruebas; nunca colocar contraseñas, tokens o documentos de identidad en Jira o repositorios.

**Inventario inicial:** base SQLite de demostración adulta (web/data/apoyo.sqlite por defecto), base estudiantil interna separada (web/data/apoyo-students.sqlite), variables de entorno y clave de IA, registros de aplicación, futuras pruebas de autorización, futuras copias de seguridad y servicios externos aún no seleccionados. Antes del despliegue, registrar ubicación, custodio, finalidad, acceso y ciclo de borrado de cada activo. No hay un depósito aprobado para la evidencia del representante.

## 2. Medidas de acceso y protección

| Control | Estado actual o acción exigida |
|---|---|
| Contraseñas y sesiones | El código guarda hashes de contraseñas y tokens, exige sesión para rutas protegidas y usa cookies HttpOnly; comprobar configuración final HTTPS y expiración al desplegar. |
| Separación de datos | Bases de adulto y estudiante separadas. El registro de menores y sus rutas reales permanecen bloqueados; no retirar la puerta hasta revisión y pruebas. |
| Acceso a datos | **Pendiente:** roles de administración mínimos, revisión de permisos de archivos/base, auditoría de accesos a evidencia y prohibición de acceso cruzado. |
| Datos en reposo y respaldos | **Pendiente:** decidir cifrado o protección equivalente de base y respaldo, gestión de claves, restauración probada, ubicación y purga. No afirmar cifrado de SQLite sin implementarlo. |
| Secretos y dependencias | Guardar claves en entorno del servidor, fuera de Git; restringir quién las ve, rotarlas ante sospecha y revisar dependencias antes de publicar. |
| IA y terceros | Registrar exactamente qué campos se envían, contrato y retención del proveedor; no enviar documentos, identidad o respuestas del menor por defecto. |
| Pruebas | Ensayar acceso directo a API sin autorización, revocación, cambio de versión, suplantación, acceso cruzado, restauración y supresión con datos ficticios. |

## 3. Atención de incidentes

1. **Detectar y registrar:** fecha/hora, quien reporta, sistema, indicios, datos y personas posiblemente afectadas. Abrir expediente restringido sin copiar datos personales innecesarios.
2. **Contener:** suspender credenciales/sesiones o componente afectado, conservar evidencias técnicas, limitar accesos; evitar borrar pruebas antes de analizarlas.

3. **Evaluar:** confirmar si hubo acceso, pérdida, alteración o divulgación de datos; distinguir adultos/menores, cantidad, sensibilidad, proveedor involucrado y riesgo. Involucrar de inmediato al responsable técnico y a privacidad.
4. **Notificar y responder:** la abogada determina deberes y destinatarios de reporte, incluido el trámite ante la SIC cuando corresponda. La SIC explica el plazo general de 15 días hábiles desde la detección y conocimiento por el área encargada; verificar el caso concreto, el canal aplicable y reglas vigentes. Definir si hay que informar a titulares/representantes, con lenguaje claro y acciones útiles.
5. **Recuperar y aprender:** corregir causa raíz, rotar secretos, verificar integridad y restauración, documentar decisiones y medidas para evitar repetición. Cerrar el caso solo con aprobación de los responsables designados.

**Registro mínimo de incidente:** ID, fecha de detección y de conocimiento por el área, hechos confirmados/no confirmados, activos, categorías de datos, medidas, decisiones de reporte y fundamento, avisos emitidos, responsable, cierre y seguimiento. **Conservación:** [plazo y protección por aprobar].

## 4. Solicitudes de titulares

Recibir por [canal pendiente] sin exigir una cuenta activa. Registrar fecha, identidad/representación verificada, derecho solicitado y respuesta. Usar el mínimo de datos para comprobar legitimación, especialmente cuando se pide información de un menor; no revelar contenido a un tercero no verificado. Clasificar como consulta, corrección/actualización, supresión, revocación o reclamo; enviar al responsable de privacidad y dejar constancia de cada acción.

Las consultas se tramitan dentro de los plazos de 10 días hábiles y posible extensión de 5; los reclamos, 15 y posible extensión de 8, con los pasos de subsanación y traslado de la Ley 1581, arts. 14–15. La solicitud de revocación debe bloquear nuevas operaciones dependientes de esa autorización cuando proceda; el responsable decide y documenta qué información debe suprimirse o conservarse por obligación legal o contractual. Implementar el borrado también en respaldos según el plazo aprobado.

## 5. Puertas antes de activar cuentas de menores

- □ Responsable y contactos reales designados; política, formulario, textos para menores y términos aprobados con versión y fecha.
- □ Finalidades, datos, destinatarios, IA y conservación aprobados; contratos y ubicación de proveedores documentados.
- □ Verificador independiente de identidad y vínculo legal, opinión del menor y evidencia protegida funcionando y probados.
- □ Control de acceso, cifrado/protección de base y respaldos, registro de incidentes y canal de derechos operativos.
- □ Pruebas de rechazo, revocación, suplantación, acceso cruzado, retención/supresión y restauración superadas con datos ficticios.
- □ Revisión jurídica y técnica de la versión exacta; autorización explícita del responsable para publicación.

### Base consultada

Ley 1581 de 2012, arts. 14–18 · Decreto 1377 de 2013, arts. 8–13 · SIC: guía de gestión de incidentes.